

Отчёт по результатам тестирования на проникновение инфраструктуры компании

Заказчик: SoftwareSolutions (ООО Софтвер Солюшнз)

Исполнитель: Корольков Д.А. _____

Шаг 1. Сбор информации об инфраструктуре

Проведено сетевое сканирование инфраструктуры и определены активные узлы, открытые порты, версии сервисов и предполагаемые роли хостов.

Описание результатов сканирования:

Хост 1

Имя хоста: ws01.acme.skb

IP: 10.0.20.11

ОС: Windows 10 / Windows Server 2019

Открытые порты: 135, 139, 445, 3389, 5985, 5986, 47001, 49664–49677

ПО: Microsoft RPC, SMB, RDP 10.0.17763, WinRM. Все порты стандартные.

Хост 2

Имя хоста: dc01.acme.skb

IP: 10.0.20.51

ОС: Windows Server 2019

Открытые порты: 53, 88, 135, 139, 389, 445, 464, 593, 636, 3268, 3269, 3389, 5985, 5986, 9389, 49666–49687

ПО: DNS, Kerberos, LDAP, SMB, RDP, WinRM. Используются стандартные порты.

Хост 3

Имя хоста: webserver02.acme.skb

IP: 10.0.20.60

ОС: Linux 5.x (Debian/Ubuntu)

Открытые порты: 22, 80, 31338

ПО: OpenSSH 8.2p1, Apache 2.4.38, WordPress 5.3, phpMyAdmin. Порт 31338 нестандартный.

Хост 4

Имя хоста: webserver01.acme.skb

IP: 10.0.20.61

ОС: Linux 5.x (Ubuntu)

Открытые порты: 22, 80, 3306

ПО: OpenSSH 8.2p1, Apache 2.4.41, DVWA, MariaDB 10.3.38. Порты стандартные.

Хост 5

Имя хоста: Не определено

IP: 10.0.20.254

ОС: Сетевое устройство
Открытые порты: Открытых TCP-портов не обнаружено
ПО: Предположительно шлюз подсети.

Шаг 2. Сбор данных в открытых источниках

Проведён анализ сайта заказчика <http://softwaresolutions.acme.skb> на наличие чувствительной и полезной для атакующего информации. Выявлены технологии, пользователи, точки входа и следы предыдущей активности.

Описание результатов изучения веб-сайта:

Технологии и версии:

Технология	Версия	Источник	Важность
WordPress	5.3	WPScan / оба файла	Критично (устаревшая)
Social Warfare (плагин)	3.5.2	contacts/	Критично — RCE (CVE)
WP File Upload (плагин)	5.3	contacts/	Высокий
WP Advanced Search (плагин)	5.3	contacts/	Средний
Тема WordPress	Twenty Nineteen 1.4	WPScan	Устаревшая
jQuery	1.12.4-wp	оба файла	Устаревший
Apache	2.4.38	nmap / WPScan	Устаревший
PHP	7.1.33	WPScan (X-Powered-By)	Устаревший

Пользователи и контакты:

Сущность	Значение	Источник	Применение
Имя пользователя	Zinaida Rogova	contacts/ (комментарий)	Логин для брутфорса
Имя пользователя	Следак_в_законе	contacts/ (комментарий)	Логин / никнейм
Пользователи WP (WPScan)	admin, buh, Editor	WPScan (Author ID brutng)	Брутфорс паролей
Организация	ООО Софтвр Солюшнз	оба файла	Инфо

Точки входа и атаки:

URL / путь	Описание	Вектор атаки
/wp-login.php	Форма входа WordPress. Поля: log, pwd	Брутфорс Hydra/WPScan
/wp-admin/	Панель администратора	После брутфорса
/xmlrpc.php	XML-RPC интерфейс (включён)	Брутфорс / DDoS
/wp-admin/admin-ajax.php	AJAX endpoint	Social Warfare RCE
/contacts/	Страница контактов с публикациями	Сбор данных о пользователях
/2023/04/12/hack-me-if-you-can/	Публикация на сайте	Изучить содержимое
/readme.html	Readme WordPress (публично доступен)	Раскрытие версии

Шаг 3. Сканирование инфраструктуры

Выполнено сканирование инфраструктуры с помощью OpenVAS. Обнаруженные уязвимости представлены в таблице.

ID уязвимости	Краткое описание	Уровень угрозы	Потенциальные риски
CVE-2016-2183	Поддержка уязвимых TLS-шифров 3DES (SWEET32)	High	Перехват или раскрытие конфиденциальных данных
TLS-Deprecated	Поддержка TLS 1.0/1.1	Medium	Использование известных криптографических атак (BEAST, FREAK)
Weak-Cert-SHA1	Сертификат подписан слабым алгоритмом SHA-1	Medium	Снижение доверия к сертификату, риск подделки
RPC-Enum	Перечисление служб DCE/RPC и MSRPC	Medium	Утечка информации о системе для последующих атак
CVE-2024-24813*	Adminer < 4.16.0: множественные уязвимости	Critical/High	Удалённое выполнение кода, раскрытие данных
Adminer-InfoDisclosure	Adminer 1.12.0–4.6.2: раскрытие информации	High	Получение чувствительных данных
Adminer-DoS	Adminer ≤ 4.8.1: отказ в обслуживании	Medium	Недоступность веб-сервиса
HTTP-Cleartext	Передача чувствительных данных по HTTP	Medium	Перехват учётных данных и сессионных токенов
HTTPOnly-Missing	Отсутствует атрибут HttpOnly у cookie	Medium	Кража cookie через XSS

Sensitive-File	Доступ к чувствительным файлам через HTTP	Critical	Компрометация конфиденциальных данных
SCM-Exposure	Доступны каталоги/файлы системы контроля версий	High	Утечка исходного кода и конфигураций
SSH-Weak-MAC	Поддерживаются слабые MAC-алгоритмы SSH	Low	Снижение криптографической стойкости соединения
WP-InfoExposure	WordPress < 6.5: раскрытие приватной информации	Medium	Получение внутренних данных сайта
WP-InfiniteWP-Info	InfiniteWP Client: раскрытие информации	High	Получение сведений для развития атаки
WP-InfiniteWP-Auth	InfiniteWP Client: обход аутентификации	Critical	Несанкционированный доступ к администрированию
WP-SocialWarfare-XSS	Social Warfare < 3.5.3: XSS	High	Выполнение вредоносного JavaScript в браузере пользователя
PHPInfo	Доступен вывод phpinfo()	Medium	Утечка конфигурации сервера
EasyPHP-Multiple	EasyPHP Webserver ≤ 12.1: множественные уязвимости	High	Компрометация веб-сервера

Шаг 4. Анализ файловой структуры веб-сервера

В ходе перебора директорий и файлов с использованием DirBuster и Gobuster были обнаружены административные интерфейсы, служебные файлы и признаки использования WordPress в качестве CMS.

Описание обнаруженной конфигурации:

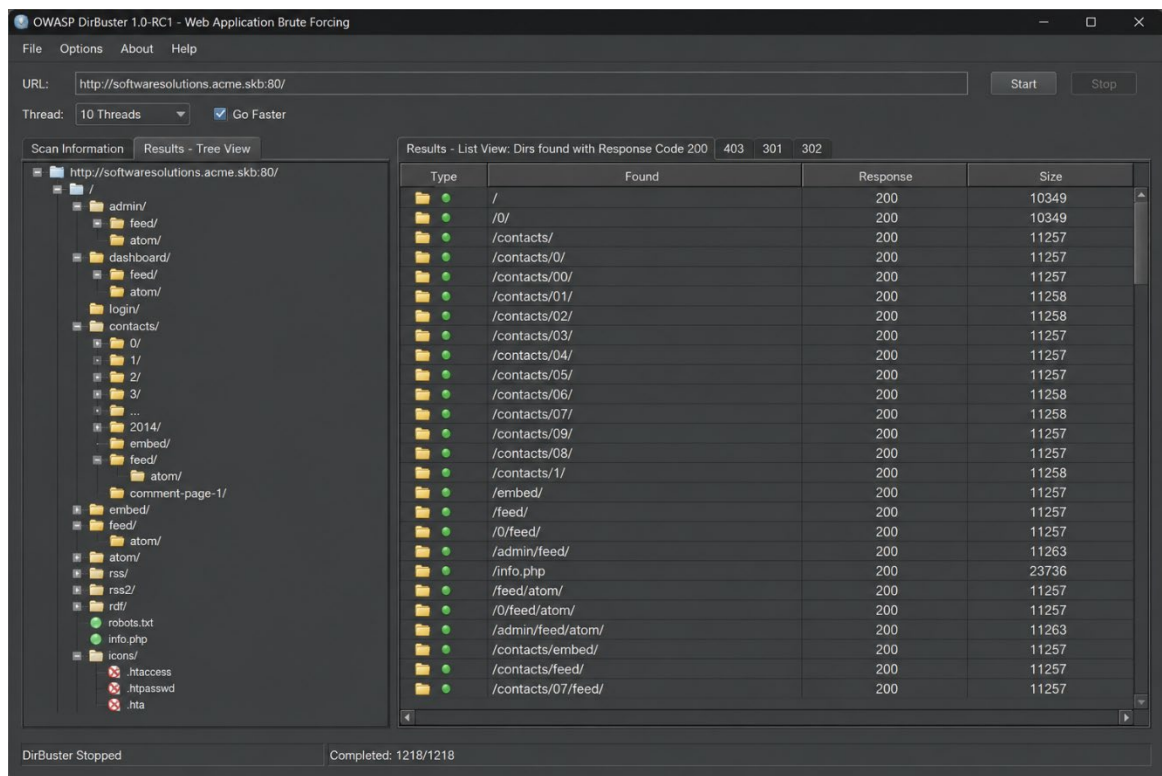
Результаты DirBuster:

Объект	Код ответа	Значимость	Комментарий
/info.php	200	Высокая	Содержит вывод phpinfo() — версия PHP, модули, пути, переменные окружения

/admin/	302	Высокая	Перенаправление на административную панель wp-admin
/dashboard/	302	Высокая	Интерфейс управления сайтом (wp-admin)
/login/	302	Высокая	Перенаправление на wp-login.php
/robots.txt	200	Средняя	Содержит /wp-admin/ и /wp-admin/admin-ajax.php
/.htaccess, /httpasswd, /.hta	403	Средняя	Подтверждает использование Apache; доступ запрещён
/server-status	403	Средняя	Включён mod_status Apache; при ошибке ACL раскрывает внутреннюю информацию
/contacts/	200	Средняя	Большое количество записей; возможна утечка служебной информации

Найденная информация в файлах:

Название файла / ресурса	Найденная информация
/robots.txt	Пути: /wp-admin/, /wp-admin/admin-ajax.php/ Login: student/ Buh Password: PerfectionPersonified
/info.php	PHP 7.1.33, модули сервера, пути к файлам, переменные окружения
/contacts/ (страница)	Имя пользователя: Zinaida Rogova; никнейм: Следак_в_законе; плагины Social Warfare 3.5.2, WP File Upload
/wp-login.php (артефакты)	SQL-инъекция: 1' OR '1'='1 — следы попытки SQLi; уникальный ID: 78082588667.945593



Шаг 5. Проникновение

С использованием данных, полученных на этапах сбора информации из открытых источников и анализа файловой структуры, предпринята попытка получения доступа к системе компьютера главного бухгалтера.

Попытка найти пароль путем перебора через hydra и словарем goskyou не увенчалась успехом. Но анализируя повторно найденную информацию пароль был найден. BUN/ PerfectionPersonified

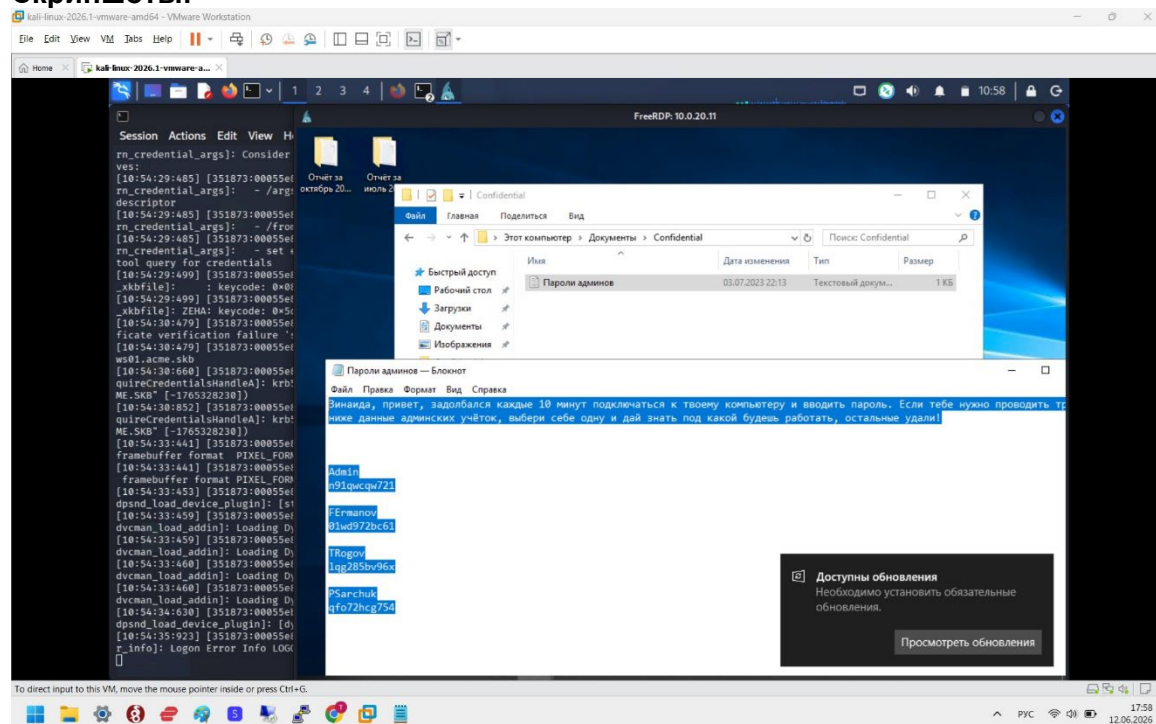
В ходе анализа файла /wp-login.php и сопутствующих артефактов был обнаружен файл с учётными данными администраторов домена.

Учётные данные администраторов домена:

Пользователь	Пароль	Примечание
Admin	n91qwcqw721	Учётная запись администратора
FErmanov	01wd972bc61	Учётная запись администратора
TRogov	lqg285bv96x	Учётная запись администратора
PSarchuk	qfo72hcg754	Учётная запись администратора
Buh / Zinaida Rogova	PerfectionPersonified	Учётная запись бухгалтера (RDP: 10.0.30.13)

Путь к файлу с учётными данными: Обнаружен в переписке/файле на компьютере бухгалтера (ws01.acme.skb, 10.0.20.11) Документы/Confidential

Скриншоты:



____ [ВСТАВИТЬ СКРИНШОТЫ]

Дополнительно обнаружен публичный SSH-ключ:

```
ssh-rsa AAAAB3NzaC1yc2EAAAADAQAB... student@acme.skb
```

Шаг 7. Рекомендации по повышению уровня безопасности

- Social Warfare 3.5.2 содержит критическую уязвимость RCE — необходимо немедленно обновить плагин до актуальной версии (4.5.6+) или удалить его, если не используется.
- WordPress 5.3 является устаревшей версией с известными уязвимостями — необходимо обновить CMS до актуальной версии.
- XML-RPC интерфейс (/xmlrpc.php) следует отключить, если не используется, во избежание брутфорса паролей и DDoS-атак.
- PHP 7.1.33 вышел из поддержки в декабре 2019 — необходимо обновить до поддерживаемой версии (8.1+).
- Apache 2.4.38 является устаревшей версией — необходимо обновить до актуальной.
- Файл /info.php (phpinfo) должен быть удалён или закрыт с сервера — он раскрывает критическую конфигурационную информацию.
- Файл /readme.html WordPress необходимо удалить или ограничить доступ во избежание раскрытия версии CMS.
- Модуль Apache mod_status должен быть отключён или жёстко ограничен по IP-адресу.

- Хранение учётных данных администраторов в незашифрованном виде (в переписке/файлах) недопустимо — необходимо использовать менеджеры паролей и принципы минимальных привилегий.
- Политика паролей требует пересмотра: все обнаруженные пароли должны быть немедленно сменены, необходимо ввести требования к сложности и ротации паролей.
- WP File Upload на странице контактов необходимо настроить с ограничением типов файлов или отключить, чтобы исключить загрузку веб-шеллов.
- Нестандартный порт 31338 на хосте webserver02.acme.skb требует дополнительного расследования и, при отсутствии необходимости, — закрытия.

Шаг 8. Вывод

В ходе проведённого тестирования на проникновение инфраструктуры компании SoftwareSolutions (ООО Софтвер Солюшнз) были выявлены существенные уязвимости, которые позволяют злоумышленнику получить несанкционированный доступ к корпоративной инфраструктуре.

Наиболее критичными находками являются: использование устаревшего плагина WordPress Social Warfare 3.5.2 с уязвимостью RCE, открытый XML-RPC интерфейс, устаревшие версии WordPress (5.3), PHP (7.1.33) и Apache (2.4.38), а также наличие в системе учётных данных администраторов домена, хранящихся в незашифрованном виде.

Особую опасность представляет факт обнаружения учётных данных нескольких администраторов домена (Admin, FErmanov, TRogov, PSarchuk) и бухгалтера (Buh/Zinaida Rogova), что создаёт реальную угрозу полной компрометации инфраструктуры компании.

Для устранения выявленных уязвимостей рекомендуется незамедлительно выполнить мероприятия, указанные в Шаге 7 настоящего отчёта.

